

ISMS MANAGEMENT REVIEW MINUTES

Tumaini Capital Ltd | ISMS-MR-001 | ISO/IEC 27001:2022 — Clause 9.3 | Fictional case study

Document ID	ISMS-MR-001 Version 1.0 First Management Review
Meeting Date	20 October 2026
Meeting Format	In-person — Nairobi HQ Boardroom
Chaired By	Chief Executive Officer
Attendees	CEO (Chair); Head of Risk & Compliance / ISMS Lead; Head of Engineering; Head of Operations; Head of HR/Finance (observer)
Apologies	None
Standard Reference	ISO/IEC 27001:2022 Clause 9.3 — Management Review Inputs and Outputs
Document Status	Approved — signed by CEO at close of meeting

1. PURPOSE

This document records the findings and decisions of Tumaini Capital's first formal ISMS management review, conducted in accordance with Clause 9.3 of ISO/IEC 27001:2022. The review assessed the suitability, adequacy, and effectiveness of the ISMS and identified actions required to address the inputs below. These minutes constitute mandatory documented information under the standard.

2. REVIEW INPUTS AND DISCUSSION

The following agenda items are required inputs under Clause 9.3. Each was presented and discussed in sequence.

2.1 Status of actions from previous management reviews

This is the first management review; no previous review actions exist. The ISMS Lead confirmed that the implementation is proceeding against the 12-month project plan established in the Risk Treatment Plan (ISMS-DOC-007). Agreed: N/A for this review cycle.

2.2 Changes in external and internal issues relevant to the ISMS

External: The ISMS Lead reported that the Office of the Data Protection Commissioner issued sector-specific guidance for digital lenders in August 2026, reinforcing the 72-hour breach notification requirement and flagging that ODPC audit activity in the fintech sector would increase in Q4 2026. The CEO confirmed this increases urgency around ODPC compliance items in the ISMS. No material change to the CBK regulatory landscape was noted.

Internal: The Head of Engineering reported that the organization has begun evaluating a third credit reference bureau integration, which would introduce a new third-party data interface. The ISMS Lead noted this would require a supplier risk assessment before go-live and an update to the asset register and SoA. The CEO agreed to ensure the ISMS Lead is included in the procurement process for this integration.

2.3 Information security performance — audit results

The ISMS Lead presented the internal audit report (ISMS-AUD-001, September 2026). The CEO and Head of Engineering reviewed the findings summary. Key points noted:

- Three Major Nonconformities were identified: unsigned IS Policy, unsigned SoA, and zero staff awareness training.
- Four Minor Nonconformities were identified, including incomplete MFA rollout, no backup recovery test, unverified logging, and no access review conducted.

- The ISMS Lead confirmed that MNC-001 (IS Policy sign-off) and MNC-002 (SoA sign-off) were closed on 14 October 2026 — the CEO signed both documents at that session. Evidence retained in the Document Register.
- MNC-003 (awareness training) and mnc-004 (access review) remain open; target dates are 27 October 2026 and 29 September 2026 respectively.

The Head of Engineering confirmed the access review (mnc-004) was completed on 26 September 2026. Three stale accounts were identified and deactivated: one CRM account, one Google Workspace account, and one AWS IAM account. Evidence retained in the access review log.

2.4 Information security performance — IS objectives progress

The ISMS Lead presented the current status against the five IS objectives:

- Objective 1 (ISO 27001 certification within 12 months): On track. Stage 1 audit scheduled for November 2026.
- Objective 2 (Leaver accounts deactivated within 24 hours): Process implemented. Three accounts deactivated on 26 September 2026 (access review). However, the 24-hour SLA has not yet been tested on a live leaver event since the policy went live. The Head of HR confirmed the next departure should be used as a test case.
- Objective 3 (Zero major nonconformities in first internal audit): Not met — three Major NCs identified. Two have been closed; one (MNC-003, awareness training) remains open. Revised target: close before Stage 1 audit.
- Objective 4 (Platform availability 99.5%): The Head of Engineering reported 99.7% uptime for the core lending platform in the preceding three months. No significant outages recorded. Noted as conformant.
- Objective 5 (90% staff training within 6 months): Not yet achieved — 0% completion at time of audit. First training session scheduled 27 October 2026. The CEO expressed concern about this and directed the ISMS Lead to report completion percentage at the next management review.

2.5 Information security performance — nonconformities and corrective actions

The corrective action register (ISMS-AUD-001) was reviewed. Current status at 20 October 2026: two of ten items closed (MNC-001, MNC-002); one in progress and due within the week (MNC-003); five are due within the month; two with November targets. The CEO directed that all Major NC and Minor NC items must be closed before the Stage 1 audit.

2.6 Monitoring and measurement results

The ISMS Lead acknowledged that formal IS metrics collection has only recently commenced following the OFI-003 audit finding. Metrics available at this review: MFA enrolment rate (AWS: 86%; Google Workspace: enforced as of 13 October 2026, 100%); access review completed (100% of in-scope systems reviewed); training completion 0% (session scheduled). Agreed: full metrics dashboard to be operational for the next management review.

2.7 Feedback from interested parties

The ISMS Lead reported that the regional bank partner's compliance team made contact in September 2026 to request a progress update on ISO 27001 certification. The ISMS Lead provided a summary of the implementation status and the Stage 1 audit date. The bank partner responded positively and indicated they will defer the contract signing decision pending Stage 1 audit completion. No formal complaints from the ODPC, CBK, or borrowers relating to information security were received in the review period.

2.8 Risk assessment results and risk treatment plan status

The ISMS Lead summarized the risk register status. Inherent risk distribution: three Critical, seven High, eleven Medium, two Low. Current treatment plan completion: Phase 1 (Months 1–2) approximately 70% complete; Phases 2 and 3 in progress. The Head of Engineering confirmed the following Phase 1 items remain

open: awareness training (MNC-003), backup recovery test (mnc-002), and Logging Policy finalization (mnc-003). All three have target dates before end of October 2026.

Noted: the risk assessment is based on the threat and vulnerability landscape as of June 2026. The ISMS Lead recommended a formal risk review in Q1 2027 following certification to update the assessment against any new threats. The CEO agreed.

2.9 Opportunities for continual improvement

Three improvement opportunities were identified:

- The flat network architecture at both offices was noted as a persistent risk. The ISMS Lead recommended escalating VLAN segmentation (currently Phase 3) to Phase 2 given the high residual risk rating. The Head of Engineering estimated 4–6 weeks for implementation. CEO approved the prioritization change.
- The ISMS Lead recommended establishing a quarterly IS steering meeting (separate from the annual management review) to provide more frequent oversight of risk treatment progress. The CEO agreed and directed the first quarterly meeting to be scheduled for January 2027.
- The Head of HR raised the need for information security requirements to be incorporated into all new job descriptions, particularly for roles with access to Restricted data. The ISMS Lead will develop standard security language for job descriptions within 30 days.

3. MANAGEMENT REVIEW OUTPUTS — DECISIONS AND ACTIONS

In accordance with Clause 9.3.3, the following decisions and actions were agreed at this review:

#	Action	Owner	Target	Status
MR-001	Close MNC-003: deliver first staff security awareness training session to all 85 staff by 27 October 2026 and retain attendance records. Report completion to ISMS Lead.	ISMS Lead	27 Oct 2026	Open
MR-002	Complete backup recovery test (mnc-002) and provide written results to ISMS Lead by 27 October 2026.	Head of Engineering	27 Oct 2026	Open
MR-003	Finalize and approve the Logging Policy; confirm full CloudTrail and CRM audit log coverage (mnc-003) by 13 October 2026.	Head of Engineering	13 Oct 2026	Open
MR-004	Escalate VLAN segmentation to Phase 2 priority; commence implementation planning. Present design to ISMS Lead by 15 November 2026.	Head of Engineering	15 Nov 2026	Open
MR-005	Ensure the ISMS Lead is included in procurement process for new credit bureau integration. Supplier risk assessment to be completed before go-live.	CEO / Head of Engineering	On procurement initiation	Open
MR-006	Develop standard information security language for all new job descriptions, specifically for roles with access to Restricted data.	ISMS Lead / Head of HR	30 Nov 2026	Open
MR-007	Schedule quarterly IS steering meeting. First meeting: January 2027. ISMS Lead to circulate standing agenda.	ISMS Lead	15 Nov 2026	Open
MR-008	Confirm Stage 1 audit date with certification body. Communicate date to CEO, Head of Engineering, and Head of Operations.	ISMS Lead	13 Oct 2026	Open
MR-009	Ensure all remaining open audit findings (mnc-001 through OFI-003) are closed before Stage 1 audit. ISMS Lead to confirm status to CEO by 7 November 2026.	ISMS Lead	7 Nov 2026	Open

#	Action	Owner	Target	Status
MR-010	Confirm current ISMS budget sufficiency through to Stage 2 audit. Head of Finance to review and report to CEO.	CEO / Head of Finance	30 Oct 2026	Open

4. REVIEW CONCLUSION

The management review confirmed that the ISMS is suitably scoped, adequately resourced, and making effective progress toward certification. The immediate priority is closing the three remaining Major Nonconformity corrective actions before the Stage 1 audit. Top management commitment to the ISMS was formally reaffirmed at this review.

The next scheduled management review is: October 2027 (annual cycle). An interim review will be triggered if a material incident occurs or if audit findings require management decisions before the annual cycle.

Role	Name & Signature	Date
Chief Executive Officer (Chair)		
Head of Risk & Compliance / ISMS Lead		
Head of Engineering		